EUREKA HACKATHON / OT CYBERSECURITY

OTProof

Check which public security notices may affect industrial equipment, then keep the human review and evidence together.

- Compare the equipment list with public industrial security notices
- Show what matched, what did not, and what is unknown
- People decide and approve any work

OTPROOF / FIELD VIEW

READ-ONLY

No contact with industrial equipment

- 80 fictional assets
- 3 real CISA advisories
- Offline-ready demo

Why matching is harder than it looks

The security notice and the equipment list often describe the same product in different ways.

01 **Inventory identifiers and advisory product language often differ**

02 A version match can be exact, excluded, or impossible to confirm

03 Teams must preserve the source and explain what they decided

OTPROOF / FIELD VIEW

3 RECORDS

Inventory · advisory · remediation evidence

- Asset inventory
- Public advisory
- Engineering record

NIST SP 800-82 Rev. 3 final · https://csrc.nist.gov/pubs/sp/800/82/r3/final

Essential services need careful decisions

Industrial control technology helps run water, energy, and other services, so changes need engineering review.

01 **A vulnerability label alone does not prove local applicability**

02 A patch suggestion is not an approved operational change

03 Human review and source traceability belong in the workflow

OTPROOF / FIELD VIEW

NO DEVICE

Discovery or configuration change

- Operator's inventory file
- Approved public websites
- Human-led review

NIST SP 800-82 Rev. 3 final; Rev. 4 remains an initial public draft as of 26 Oct 2026.

From import to report: six clear steps

Follow the notice, compare the equipment, record the people’s decisions, and save the evidence.

01 **Check the equipment file and load public security notices**

02 Compare maker, product, model, and installed version

03 Record decisions, work approval, and supporting evidence



End-to-end journey is implemented in the MVP dashboard and API.

Demo: three assets, three distinct outcomes

A CISA FactoryTalk View advisory exposes why version and inventory quality matter.

01 **FactoryTalk View SE 13.0.0 → possible match**

02 FactoryTalk View SE 14.0 → outside the exact affected version

03 Same product with missing firmware → engineering review

OTPROOF / FIELD VIEW

ICSA-24-226-06

CISA notice · published 13 Aug 2024 · updated 29 Aug 2024

- CVE-2024-7513
- Source statement: version 13.0
- Source URL retained

https://www.cisa.gov/news-events/ics-advisories/icsa-24-226-06

No unsupported guesses: show the matching rules

Compare exact product and version details. If the records are incomplete, ask a person to check.

01 **Correct only known spelling variations**

02 Compare the installed version with the notice’s affected version or range

03 Send missing, old, duplicate, or unclear records to human review

OTPROOF / FIELD VIEW

3 OUTCOMES

Applicable · not applicable · manual verification

- Product names match
- Version fits the notice
- Reason and source link shown

Matcher implementation: backend/app/services/matching.py

AI can read; people make the decisions

An optional local AI helper suggests details from a notice. It cannot decide whether equipment is affected.

01 **Suggest product, version, vulnerability ID, and mitigation details**

02 Check suggested quotes and details against the original notice

03 Never let AI approve work or mark equipment fixed

OTPROOF / FIELD VIEW

OPTIONAL

Optional local AI · not run in evaluation

- Required fields checked
- Source details compared
- Suggestion only

Optional local model; no model weights included and no inference run in evaluation.

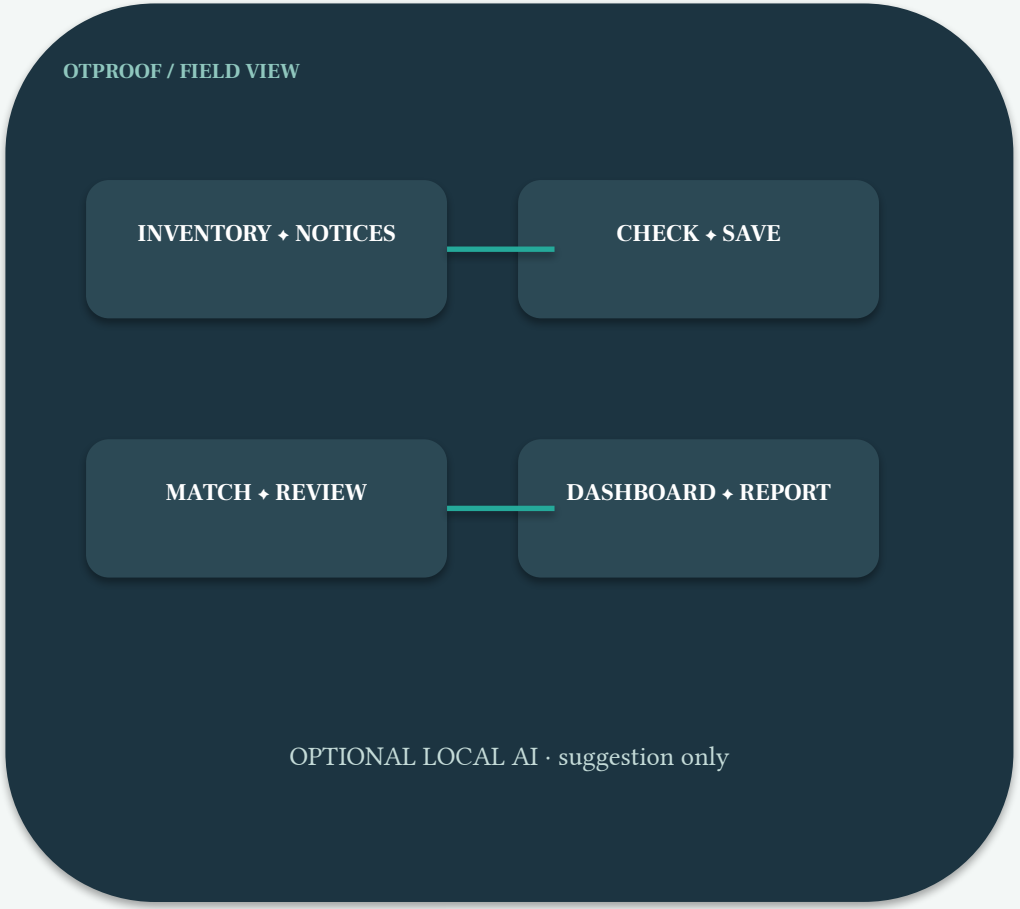
How the software is put together

A web page, one service, and a database keep the process simple to inspect and run.

01 **Web dashboard and a service that checks and compares records**

02 Database for decisions; PDF and JSON reports for handoff

03 Optional AI helper runs locally and only drafts suggestions



Full technical design: OTProof_Technical_Design.md

People own every decision

A review, a work plan, approval, and proof of completed work are separate steps.

01 **Reviewer records applicability with a rationale**

02 Engineer proposes action; approver accepts or rejects

03 Approver verifies evidence before the workflow closes

OTPROOF / FIELD VIEW

4 ROLES

Engineer · reviewer · approver · admin

- Decision
- Ticket
- Evidence
- Verification

Demo passwords are visible; company login is needed before real use.

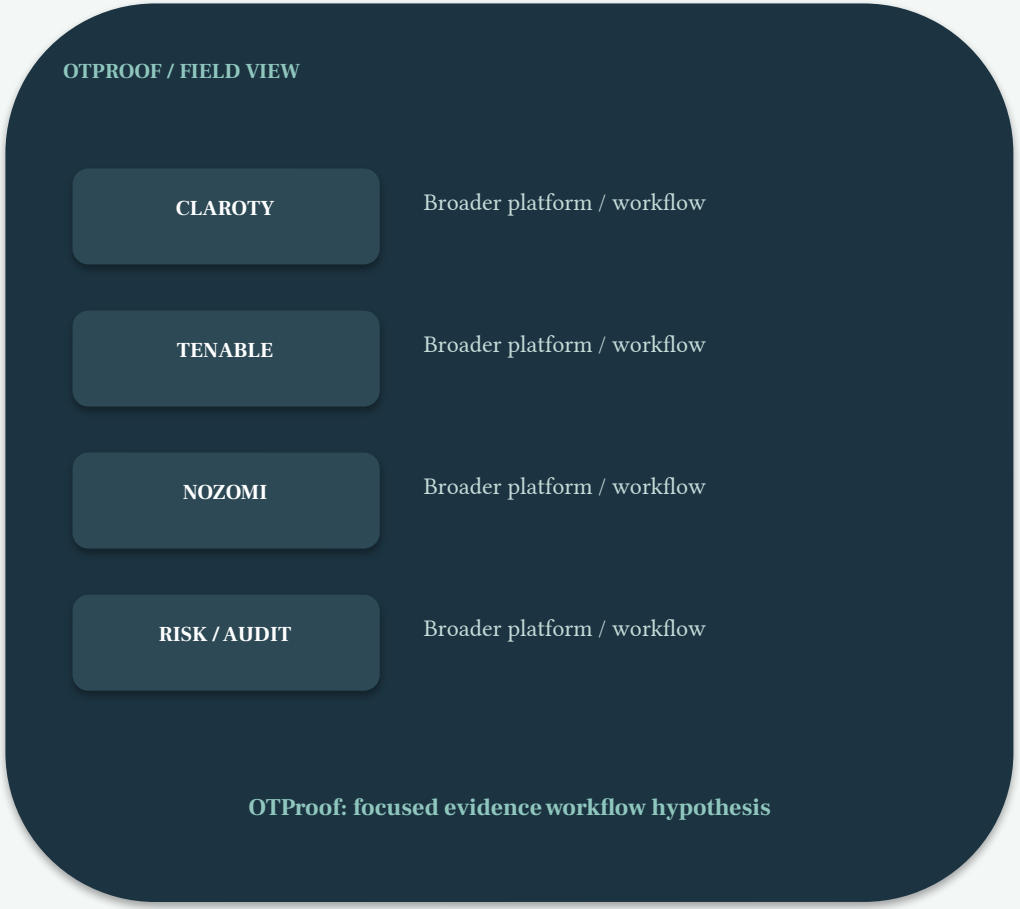
Where OTProof could fit

Existing security platforms may already help. OTProof's possible role is a focused review and evidence workflow.

01 **OT security platforms offer asset visibility and vulnerability management**

02 Risk and compliance tools track controls, reviews, and audit records

03 Test whether this focused workflow fills a real gap or connects to them



Claroty · Tenable · Nozomi · ServiceNow public product documentation; see notes.

A possible per-site subscription model

The example prices below are assumptions to test with buyers, not sales or a forecast.

01 **Example annual license: $36,000 per site**

02 Example one-time setup: $25,000 per new customer

03 Other options: enterprise plans, integrations, and review services

OTPROOF / FIELD VIEW

1 customer	$108k / year
5 customers	$540k / year
10 customers	$1.08m / year
25 customers	$2.70m / year

Illustrative arithmetic only; assumptions in OTProof_Business_Case.pdf.

What the test shows—and what it does not

The software matched this small set of prepared examples; the result does not predict field accuracy.

01 **All 14 labeled test cases matched their expected outcome**

02 All 4 affected examples were found; none were missed in this set

03 All 6 uncertain examples went to human review; all results link to sources



Safety and trust boundaries

The app reads files and public notices. It never contacts or changes industrial equipment.

01 **No device scan, remote query, exploit, or configuration change**

02 Uploaded files and notice text are treated as untrusted input

03 People approve work and check evidence before closing a finding

OTPROOF / FIELD VIEW

HUMAN

Owns applicability and remediation decisions

- Public sources only
- Evidence and action history
- Company login needed for real use

Security review, company login, and protected action records remain future work.

Next: test with operators and engineers

The next step is to learn whether this helps real teams and fits their existing process.

01 **Invite 3–5 operators or service providers to try a controlled pilot**

02 Ask engineers to label cases before seeing the software's result

03 Measure missed cases, human-review rate, time, and setup effort

OTPROOF / FIELD VIEW

PILOT ASK

Water / energy operator + OT engineering reviewers

- Add more vendors and sources
- Add company sign-in and protected audit records
- Connect to maintenance and risk systems if users need it

No customer interviews, paid pilots, or measured savings are claimed yet.

Plain-language glossary

A quick translation of the terms used in this presentation.

01 **Asset: a device or software record in the operator's equipment list**

02 Advisory: a public security notice about a product weakness

03 Candidate match: a possible link that still needs an engineer's review

04 Evidence: a record that supports a human decision

OTPROOF / FIELD VIEW

KEY TERMS

Read the source and inventory record together

- OT · computers and controllers for physical processes
- CISA · U.S. Cybersecurity and Infrastructure Security Agency
- CVE · public ID assigned to a specific vulnerability
- KEV · CISA list of vulnerabilities known to be exploited

More terms and examples: README.md and OTProof_Technical_Design.md